

Pille Lehis
Andmekaitse Inspektsioon
Tatari 39, 10134 Tallinn
info@aki.ee

MÄRGUKIRI

08.04.2026

Lugupeetud Andmekaitse Inspektsiooni peadirektor

Käesoleva märgukirjaga juhime Andmekaitse Inspektsiooni (edaspidi Inspektsioon) tähelepanu SK ID Solutions AS-i (edaspidi SK) kui isikuandmete vastutava töötaja tegevusele, mis puudutab andmesubjektide (Smart-ID kasutajate) läbipaistvuse põhimõtte ja vaikimisi andmekaitse rikkumist Euroopa Parlamendi ja nõukogu määruse (EL) 2016/679 (IKÜM) artiklite 5, 12, 13 ja 25 tähenduses.

Märgume esmalt selgelt, mida käesolev märgukiri ei puuduta:

1. Me ei vaidlusta Smart-ID krüptograafilist turvalisust ega eIDAS LoA High sertifikaadi kehtivust – tehniliste standardite (ETSI) ja usaldusteenuse järelevalve on Riigi Infosüsteemi Ameti (RIA) ainupädevuses.
2. Me ei nõua, et SK dikteeriks e-teenuste pakkujatele (Relying Party, edaspidi RP) lepingulisi turvanõudeid, ega sekku RP-de kui iseseisvate vastutavate töötajate riskihinnangutesse.
3. Me ei nõua Smart-ID rakendusse kasutajakogemust rikkuvate hoiatuste (nn warning fatigue) lisamist iga autentimise juurde.

Käesolev märgukiri keskendub eranditult asümmeetrilisele teavitamisele: asjaolule, et SK teavitab B2B arendusdokumentatsioonis RP-sid teatud autentimisvoogude kõrgendatud riskidest ja vajadusest tugineda "kasutaja teadlikkusele", kuid varjab seda kriitilist teavet andmesubjekti (lõppkasutaja) eest B2C privaatsustingimustes ning ei võimalda andmesubjektil oma seadmes ohustatumat voogu välja lülitada.

1. Faktilised asjaolud ja infovahetuse asümmeetria

SK töötleb Smart-ID teenuse käigus miljonite Eesti kodanike isikuandmeid

(identifitseerimisandmed, seadmeandmed, autentimisessioonid).

SK tehnilises dokumentatsioonis (Smart-ID RP API v3, avalik B2B vaade) on selgelt eristatud kaks autentimisvoogu:

1.1. Seadmesisese lingi vood (Device link flows / App-to-App): Krüptograafiliselt seansiga seotud turvalisem lahendus, kus kaug-vahendajärinne (MitM / phishing) on välistatud.

1.2. Teavitusepõhine autentimisvoog (Notification based flow): SK dokumentatsioonis B2B klientidele ametlikult märgitud kui "ebasoodsam lahendus" (less recommended solution), mille puhul turvalisus sõltub kriitilisel määral inimese kognitiivsest tähelepanust – st kasutaja suutlikkusest kontrollida 4-kohalist koodi. Selles voos toimib inimene ise süsteemi "tulemüürina".

Probleem: SK privaatsuspoliitikas, teenusetingimustes ega Smart-ID rakenduse seadetes ei anta andmesubjektile teavet, et süsteemis eksisteerivad erineva riskiprofiliga autentimisvood, mille puhul ühes langeb krüptograafiline kontrollikoorem ja vastutus ründe (phishing) vältimise eest täielikult andmesubjekti õlule. Samuti puudub Smart-ID rakenduses tehniline võimalus (lüliti), millega kasutaja saaks oma kontol ebasoodsama lahenduse (teavitusepõhise voo) keelata, kui ta seda ei soovi.

2. Õiguslik hinnang

2.1. Õigluse ja läbipaistvuse põhimõte (IKÜM artikkel 5 lg 1 p a, artikkel 12 ja artikkel 13)

IKÜM nõuab, et isikuandmete töötlemine peab andmesubjekti suhtes olema õiglane ja läbipaistev. See tähendab, et andmesubjekt peab mõistma töötlemisega kaasnevaid riske ja kaitsemeetmeid.

Olukord, kus vastutav töötleja (SK) deklareerib arendajatele avalikult, et Notification-based flow sisaldab olemuslikku riski (sõltuvus kasutaja ekslikkusest), kuid jätab selle teabe andmesubjekti eest varjatuks, on vastuolus läbipaistvuse põhimõttega. Andmesubjekt on infosulus. Kasutajale antakse Smart-ID rakendus ootusega, et see on läbivalt absoluutselt turvaline, samas kui SK enda riskimudel eeldab teatud voogude puhul kasutajalt kõrgendatud hoolsuskohustust. Teabe esitamine üksnes ingliskeelses B2B API dokumentatsioonis ei täida IKÜM artikli 12 (selge ja arusaadav teave andmesubjektile) nõudeid.

2.2. Vaikimisi andmekaitse andmesubjekti kontrolli vaates (IKÜM artikkel 25 lg 2)

Artikkel 25 lõige 2 ei reguleeri pelgalt andmemahte, vaid seda, et vaikimisi ei muudeta andmesubjekti andmeid piiramatult kättesaadavaks ning talle tagatakse kontrolli töötamise ulatuse üle.

Smart-ID teenuse arhitektuur sunnib andmesubjekti olema vaikimisi avatud kõikidele (sh SK enda poolt "ebasoodsamaks" hinnatud) autentimispäringutele, olenemata sellest, millisest e-teenusest need tulevad. Smart-ID mobiilirakenduses puudub andmesubjektil "vaikimisi andmekaitse" seade – näiteks võimalus seadistada oma konto nii, et see aktsepteerib ainult App-to-App (Device link) päringuid, välistades seeläbi täielikult teavitusepõhise õngitsusriski.

Kui vastutav töötleja on teadlik arhitektuursest riskust, on lõimitud ja vaikimisi andmekaitse põhimõtte kohane tagada andmesubjektile oma isiklikus seadmes (rakenduses) tehniline valikuvabadus piirata kõrge riskiga töötlusvoogusid. Kasutajalt selle kontrolli äravõtmine on

vastuolus andmesubjekti autonoomia põhimõttega IKÜM raamistikus.

2.3. Jurisdiktsiooni autonoomia: eIDAS ei välista IKÜM teavituskohustusi

Võimalikule vastuargumendile, et "eIDAS LoA High katab kõik turvanõuded", vastame ennetavalt: eIDAS sertifikaat (mis põhineb ETSI standarditel) annab kinnituse süsteemi krüptograafilisele ja tehnilisele disainile. eIDAS audit ei vabasta vastutavat töötajat IKÜM-ist tulenevast kohustusest omada läbipaistvat privaatsuspoliitikat (artikkel 13) ega kohustusest pakkuda rakenduses andmesubjektile privaatsusseadeid (artikkel 25). IKÜM läbipaistvusnõuded rakenduvad sõltumata ETSI audititest ning nende järelevalve on Eesti Vabariigis eksklusiivselt Inspektsiooni pädevuses.

3. Taotlus ja ettepanekud Inspektsioonile

Eelnevale tuginedes palume Andmekaitse Inspektsioonil:

1. Alustada järelevalvemenetlust hindamaks SK ID Solutions AS-i privaatsuspoliitika ja andmesubjektile suunatud teavituste vastavust IKÜM artiklite 5, 12 ja 13 nõuetele olukorras, kus B2B dokumentatsioonis esile toodud andmetöötlusriskid on andmesubjekti eest varjatud.

2. Küsida SK-lt ametlikku selgitust IKÜM artikli 25 lg 2 (vaikimisi andmekaitse) täitmise kohta: miks ei ole Smart-ID rakenduses andmesubjektile loodud võimalust (seadet/lüliti) keelata oma konto puhul teavitusepõhised (Notification-based) päringud, piirates töötlemise soovi korral vaid turvalisemate Device link voogudega?

3. Teha ettekirjutus, mis kohustab SK-d:

(a) viima oma andmesubjektidele suunatud teavituse ja privaatsuspoliitika vastavusse tegeliku riskimudeliga, selgitades kasutajatele arusaadavas keeles erinevate voogude olemust ja kasutaja enda rolli andmete kaitsmisel (õiglus ja läbipaistvus);

(b) lisama Smart-ID rakendusse kasutajapoolse privaatsusseade (näiteks toggle lüliti), mis võimaldab andmesubjektil rakendada enda kontol vaikimisi kõrgeimat andmekaitset (aktsepteerides vaid Device-link voogusid).

Kinnitame veelkord, et meie ettepanekud ei nõua Inspektsioonilt sisenemist tehniliste standardite hindamisse ega RIA pädevusse. Nõuame vaid andmesubjekti õigust olla töötlemise riskidest läbipaistvalt teavitatud ja omada rakenduses kontrolli oma andmetöötluse seadete üle.

Oleme valmis esitama täiendavaid selgitusi ja toetavaid materjale.

Palun vastata mulle kirjalikult e-postiga.

Lugupidamisega

(allkirjastatud digitaalselt)

Tom Kristian Abel
Märgukirja esitaja

Tom Kristian Abel

Lisad:
